

201 Malware Operasyon: “The Malware Hunter”

201 Operasyonu:The Malware Hunter

Faz 1:Mimari ve Temeller(Research and logic)

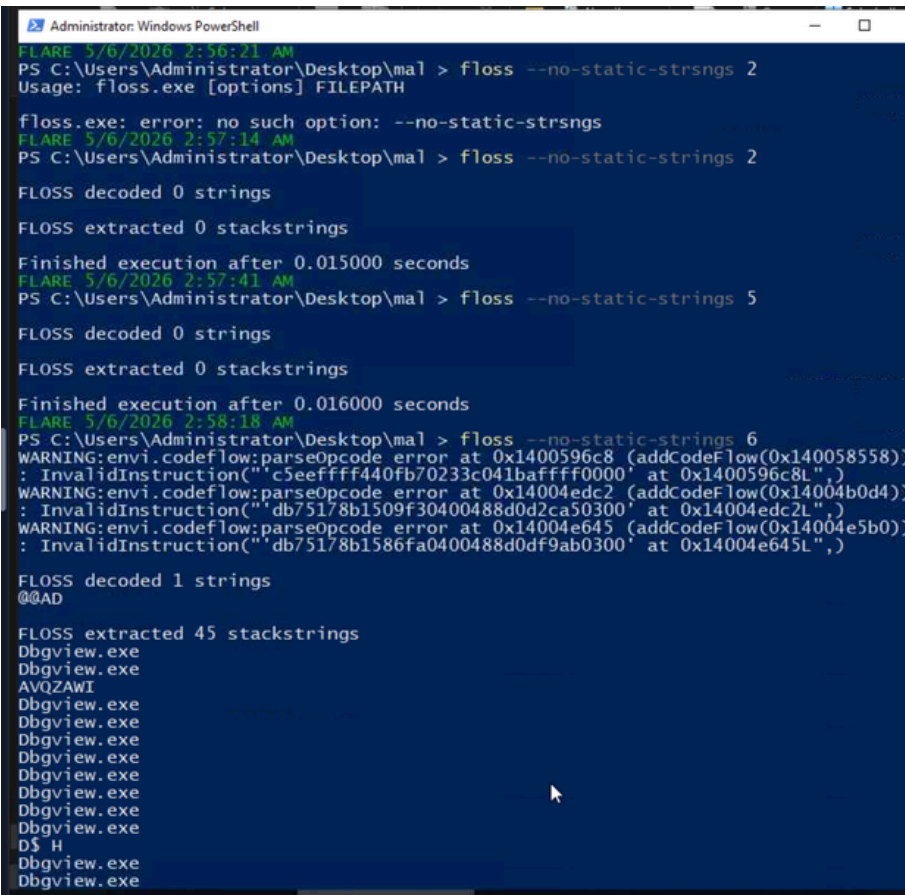
1. Analiz Türleri "Durağan ve Hareketli": Statik analiz dosyayı çalıştırmadan yapılan incelemedir. Bu aşamada dosya parçalarına ayrılır ve kaynak kodu incelenir. Dosyanın güvenli bir ortamda çalıştırılarak izlenmesidir. İçerdiği kodun sistemde yaptığı değişiklikler, oluşturduğu dosyalar ve ağ trafiği incelenir. Peki neden önce statik analiz yapılmalı sonra dinamik analiz yapılmalı? Statik analizle dosyanın yapısı incelenerek dinamik analiz sürecinde hangi adımların takip edilmesi gerektiğini belirleyebiliriz. Statik analizle geciktirme döngüleri, fare hareketleri daha birçok tetikleyici davranışla dosya hakkında kritik bilgiler edinebilirken dinamik analizle fark edemeyebiliriz. Statik analiz ile kodun içindeki "mantıksal akışı" görerek dinamik analiz sırasında hangi fonksiyonlara (API calls) ve ağ adreslerine dikkat etmeniz gerektiğini önceden belirleriz.
2. Güvenli Alan: "Kafes Sandbox" : Sandbox, şüpheli bir kodun sistemin geri kalanına zarar vermeden çalıştırılabileceği, tamamen izole edilmiş sanal ortamdır. Bu sanal ortam (guest) sayesinde zararlı yazılımın ana işletim sistemimizde (host) dosya silme, şifreleme, veri hırsızlığı gibi faaliyetlerini engellemiş oluruz. Ayrıca sanal makineyle saldırganın gerçek ağımıza ulaşmasını engellemiş oluruz. Ayrıca sanal makineyi kolayca zararlı yazılımdan arındırabiliriz.
3. Tersine Mühendislik (Reverse Engineering): "Kodu Geriye Sarmak" : Tersine mühendislik bir aygıtı, bir yapıyı parçalara ayırarak nasıl çalıştığını analiz etmektir. Derlenmiş bir exe dosyasını incelemek yazılımın hangi kütüphaneleri çağırdığını görmek assembly kodundaki jump, cmp vs. komutlarından saldırganın ne zaman ne yapmaya çalıştığını çıkarmak kodun içindeki gizli IP adresleri, dosya yollarını görmek gibi avantajlar sağlar.

Faz 2: Saha Operasyonu (Boss Fights)

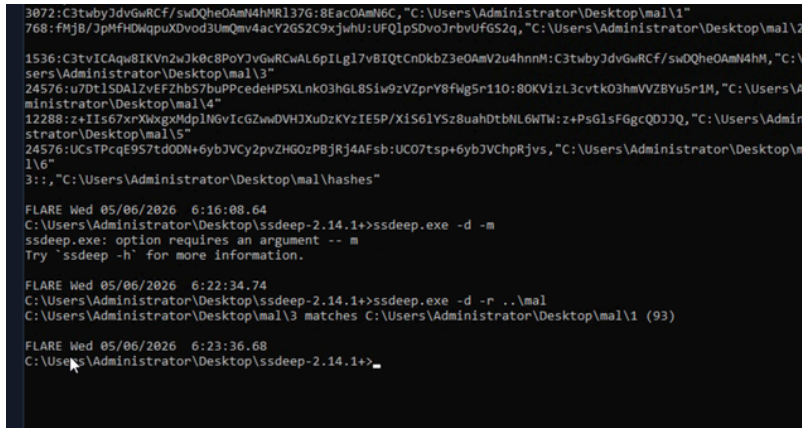
Basic static analysis

Eklı sanal makinenin masaüstünde, 1'den 6'ya kadar kötü amaçlı yazılım örnekleri içeren 'mal' adlı bir dizin bulunmaktadır. Floss kullanarak 2, 5 ve 6 numaralı örneklerde bulunan gizlenmiş dizeleri belirleyin. Bu örneklerden hangisi 'DbgView.exe' dizesini içermektedir?

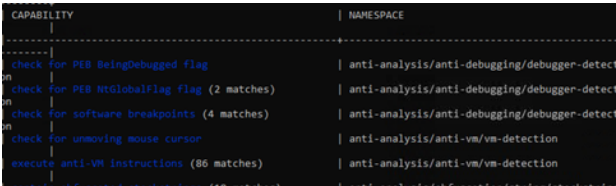
cevap:6



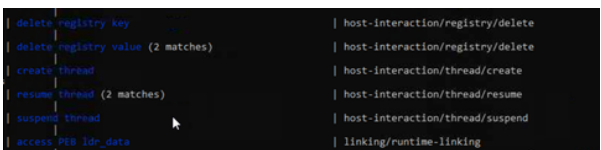
Ekli sanal makinedeki Desktop\mall dizininde bulunan örneklerden hangisinin imphash değeri 3 numaralı dosya ile aynıdır?
cevap:1



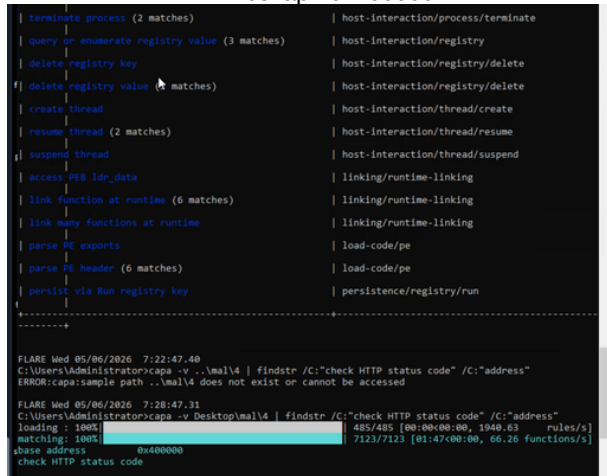
Örneklemde sanal makine yürütme karşıtı tekniklere ilişkin kaç eşleşme tespit edildi?
cevap:86



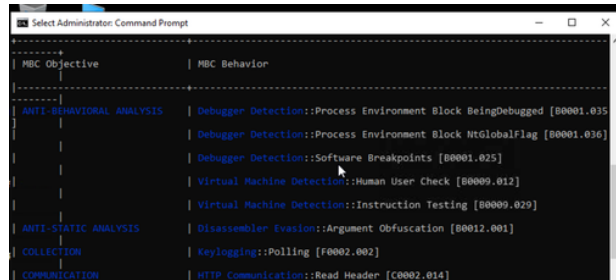
Örnek, bir iş parçacığını askıya alma veya devam ettirme özelliğine sahip mi? Evet için Y, hayır için N ile yanıtlayın
cevap:Y



'HTTP Durum Kodunu Kontrol Et' özelliğine sahip fonksiyon
hangi adreste yer almaktadır?
cevap: 0x400000

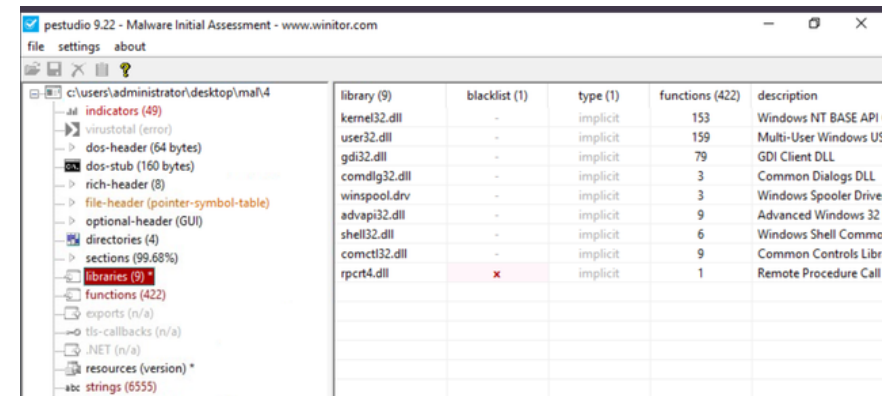


MBC'nin 'Antistatik Analiz' hedefine karşı hangi MBC davranışı gözlemlenmektedir?
cevap: Disassembler Evasion::Argument Obfuscation



PEstudio'da Desktop\mal\4 örneğini açın. Hangi kütüphane kara listeye alınmış?
cevap:rpctr4.dll

Bu DLL ne işe yarıyor?
cevap:Remote Procedure Call Runtime



	3	Common Image DLL
implicit	3	Windows Spooler Driver
implicit	9	Advanced Windows 32 Base API
implicit	6	Windows Shell Common Dll
implicit	9	Common Controls Library
implicit	1	Remote Procedure Call Runtime